

Governance-Driven Agentic Coding

How an AI-Native Company Governs Itself

A software development method in which the Owner steers and Agents execute, governed through explicit authorization, mandatory record-keeping, independent challenge, read-only reporting, and a closed learning loop.

Not several AIs writing code together — but organizing them into a production system that is governable, traceable, and replaceable.

· BUILD	· REPORT	· CHALLENGE	· TEACH	· EXTERNALIZE
---------	----------	-------------	---------	---------------

VERSION 1.4 | 2026-07-30 | ITERATED FROM CROSS-PROJECT PRACTICE |
XIAOHONGSHU @就很菜 · VEGGIEDESU

SEC. 01 Executive Summary

CORE DEFINITION

Governance-driven agentic coding is a way of building software in which the Owner sets authorization and risk boundaries, a Managing Director Agent owns delivery, and the work is governed through independent challenge, organizational records, read-only information projections, and final human accountability.

What it addresses is not "how to get more Agents working together." It addresses a more fundamental delegation problem: when a human cannot personally master every technical detail, how do you expand AI's autonomous execution without losing the objective, the judgment, the risk control, and the final responsibility?

The long-term value of this system does not depend on any particular model. Codex, Claude, or GPT are merely the current occupants of a role. What must be preserved are role responsibilities, authority boundaries, evidence, decision records, escalation rules, and the acceptance regime.

In one line: models are replaceable; roles and institutions must persist.

Five core functions

- ◆ **Build** — the Managing Director creates and delivers project value.
- ◆ **Report** — the Investor Office compresses project change into a state the Owner can actually read.
- ◆ **Challenge** — the Strategic Board independently challenges major direction and high-risk decisions.
- ◆ **Teach** — the Academy converts real project material into the Owner's comprehension and judgment.
- ◆ **Externalize** — the GTM & Narrative Office converts project evidence into verifiable external expression.

SEC. 02 **First Principle: Delegation Must Not Mean Loss of Control**

The real danger of AI coding is not only that AI writes the wrong code. The deeper risk is that when the Owner delegates execution, control, comprehension, and responsibility go out the door with it.

This method therefore holds three floors:

- ◆ AI's execution capability may keep expanding, but the Owner's final judgment cannot be transferred.
- ◆ The human need not participate in every step, but must understand the key assumptions, the irreversible decisions, and the residual risk.
- ◆ Complex work can be delegated. Responsibility for the outcome cannot.

HUMAN - IN - COMMAND

The goal is not to keep the human in every step, but to move the human out of low-value execution while keeping the human in high-value judgment.

SEC. 03 **Investor Mandate and Operating Constitution**

Investor Mandate: the highest authorization for a single project

The Investor Mandate is not an ordinary brief, nor a technical specification. It defines why the investment is being made, what is authorized, how much may be spent, which risks cannot be borne, and what result counts as success.

Vision	What real-world value the project is meant to create
Scope / Non-scope	What will be done — and explicitly what will not
Capital	Time, tokens, tools, external services, and other resources
Risk Appetite	Which risks are acceptable and which are absolutely not
Success Criteria	What evidence determines that the project succeeded
Reserved Decisions	Which matters must be decided by the Owner

Operating Constitution: the organizational discipline that does not change between projects

- ◆ No fabrication of facts, progress, test results, or business impact.
- ◆ Facts, assumptions, risks, and recommendations must be stated separately.
- ◆ Major decisions must leave behind their basis, the alternatives, and any dissent.
- ◆ Critical failures may not be hidden by a summary; irreversible operations must be escalated.
- ◆ No Agent may approve its own final delivery.
- ◆ Important knowledge may not live only in a chat window; history may not be overwritten.
- ◆ Scope may not be expanded, nor risk appetite changed, without authorization.

SEC. 04 Organization and Authority Model

The organization has two parts: a control core that can affect the Product, and a read-only derivative layer that may only read facts and generate views for different audiences.

ROLE	CORE RESPONSIBILITY	AUTHORITY	BOUNDARY	PRIMARY OUTPUT
			Xiaohongshu	@就很菜 · veggiedesu

Owner / Investor	Vision, capital, risk appetite, legal risk, final acceptance	Retains final decision rights and responsibility	Investor Mandate; accept / pause / terminate
Managing Director	Planning, architecture, delegation, quality, records, delivery	May autonomously handle ordinary engineering decisions within the mandate	Product, Project Ledger, Decision Log
Strategic Board	Independent challenge, by mandate, on major direction, long-term trade-offs, and high-risk decisions	Advice and second review only; no management, decision, or implementation authority	Board package, independent opinion, MD disposition
Investor Office	Reports the true project state from the Owner's side	Read-only; does not manage the MD or modify the Product	Project State, Dashboard, Executive Brief
Academy	Converts project facts into the Owner's understanding and judgment	Read-only; may not alter development sequencing	Project-driven teaching, Capability Ledger
GTM & Narrative	Converts what has already happened into external narrative	Read-only; may not reverse-engineer the product to fit a story	Demo, case study, narrative

Federated Strategic Board

Each project and the portfolio office preserve their own challenge context and visible record. Claude may currently occupy the advisory and second-review role through an Owner-visible Chrome conversation, but Claude is only the current role-holder and has no management, decision, or implementation authority. Advice from one mandate does not automatically become a requirement for another. Advice, MD disposition, Owner decision, implementation, and publication status must be recorded separately.

Temporary execution roles

Specialist Agents and red-team Agents are generated dynamically by the MD per task. They are not standing departments; they may exit as soon as the task ends.

any by the MD per task. They are not
Xiaohongshu @就很菜 · veggiedesu
Every temporary role must carry an

explicit mission, scope, inputs, output, completion criteria, and escalation rule.

SEC. 05 **The Standard Operating Loop**

- 01 The Owner issues an Investor Mandate stating objectives, non-objectives, resources, risk, and acceptance.
- 02 The MD converts the mandate into the shortest verifiable loop, establishing task dependencies, test strategy, and escalation points.
- 03 The MD creates Specialist Agents dynamically to carry out research, implementation, testing, documentation, or security work.
- 04 All Agent communication, decisions, failures, and fixes are recorded by mandate.
- 05 The MD completes a first round of self-checking; this is quality control, not independent audit.
- 06 Risk level determines whether dedicated red teams or the Strategic Board are triggered.
- 07 Ordinary issues are fixed by the MD; anything beyond the mandate or the risk appetite is escalated to the Owner.
- 08 The Owner performs final acceptance against the mandate: accept, accept with conditions, rework, pause, or terminate.
- 09 After the project closes, organizational memory, Owner capability, and external narrative assets are consolidated.

Review escalates by risk

RISK LEVEL	TYPICAL TRIGGER	REVIEW AND DECISION
Low · reversible	Local change, easy rollback, clear blast radius	MD self-check
Medium · cross-module	Interface change, data handling, multi-module dependency	One or two dedicated red teams

Xiaohongshu @就很菜 · veggiedesu

High · irreversible	Security, legal, capital, major architecture, launch gates	Multiple red teams + Strategic Board
Beyond mandate	Changing objectives, expanding scope, breaching budget or risk appetite	Owner decides

Review principle: the number of red teams has no value in itself; a new attack angle, a new evidence source, or a new specialist capability does. Red teams may be generated by the MD, but any high-risk review must include at least one independent perspective that the MD did not create and that does not share the MD's context — such as the Strategic Board or an independent red team. Otherwise the organization falls into the same-source self-review failure it defines for itself.

SEC. 06 **Organizational Memory**

THE KEY DIFFERENCE

What the read-only Agents read is not "what the MD told me." It is the organizational record the MD left behind.

All internal Agent communication, decisions, and fixes must leave a log; record-keeping is an institutional requirement, not something that depends on any role's diligence. The critical Decision Log follows append-only discipline: history cannot be overwritten, and any revision must fully preserve the version, the time, and the reason.

RECORD LAYER	QUESTION IT ANSWERS	CONTENTS
Project Ledger	Where the project is now	Current phase, done / in progress, risks and blockers, next milestone, key evidence
Decision Ledger	Why the project got here	Decision, context, alternatives, evidence, dissent, rationale, later validation
Raw Logs	What actually happened	Agent communication, commands, tests, failures, fixes, and their order in time.

Executive Summary	What the Owner needs to know now	Changes, health, risks, blockers, matters requiring a decision
--------------------------	----------------------------------	--

Raw logs exist for traceability; summaries exist to resume work and lower cognitive load. A summary may be rewritten, but it can never replace or delete the original record.

The value of organizational memory: being able to answer, later, "why did we choose A rather than B?" — instead of relying on some model's vague recollection.

SEC. 07 Four Information Flows

This organization is not a simple chain of command. It runs four flows at once, each with a different direction and different permissions.

Delivery Flow

Investor Mandate → MD + Specialists → Product

Answers: how the project gets done.

Reporting Flow

Material change → Mandatory log → Investor Office → Project State / Dashboard → Owner

Answers: where the project stands now.

Learning Flow

Project Facts → Academy → Owner Capability

Answers: what the Owner learned from the project.

Market Flow

Project Evidence → GTM Office → Demo / Case / Narrative → External Audience

Answers: why outsiders should understand and believe it.

Shared fact layer: Project Ledger + append-only Decision Log.

SEC. 08 The Three Read-Only Offices

Investor Office: the Owner's project secretariat

The Investor Office reports to the Owner directly. It is not the MD's secretary and does not manage the project. When mainline milestones, plans, risks, blockers, or important decisions change materially, the MD notifies it. It reads changes in the Project Ledger and Decision Log and produces the management information the Owner sees daily.

- ◆ **Project State** — current phase, health, next milestone, blockers.
- ◆ **Dashboard** — a high-density management view for the Owner.
- ◆ **Executive Brief** — material changes, major decisions, risks, recommendations.
- ◆ **Owner Decisions Required** — matters only the Owner can decide, with deadlines.

Academy: a project-driven learning system for the Owner

The Academy reads only what actually happened in the project. It does not teach abstract courses detached from the work, and it may not ask the MD to change development sequencing for teaching purposes. It answers: what happened today, why it was done this way, what mechanism sits underneath, and how the Owner might judge it independently next time.

LEARNING OBJECTIVE

Ordinary AI coding optimizes how to finish the project. The Academy further optimizes how the human becomes more capable after every project.

GTM & Narrative Office: evidence-driven external expression

The GTM Office generates demos, case studies, interview narratives, and communication material from project evidence. It may not write plans as if they were shipped, may not hide failures, and may not reverse-pressure the Product for the sake of a better story.

Xiaohongshu @就很菜 · veggiedesu

Highest discipline: Narrative follows evidence.

SEC. 09 Five Compounding Assets from One Project

Under this method, code is only one of the outputs. A single investment generates five reusable assets at once.

- ◆ **Product** — a deliverable that can be run, tested, demonstrated, or iterated further.
- ◆ **Organizational Memory** — mandatory records, a fully preserved Decision Log, an error catalogue, and the record of how the institution itself evolved.
- ◆ **Project State + Dashboard** — sustainable management information generated for the Owner by the Investor Office.
- ◆ **Owner Capability** — conceptual understanding, risk judgment, and independent decision-making consolidated by the Academy.
- ◆ **Demo / Case / Narrative** — external, professional, and commercial assets generated by the GTM Office.

THE COMPOUNDING LOGIC

The project advances, the organization accumulates memory, the Owner accumulates judgment, and the work accumulates external visibility — all from the same investment.

SEC. 10 Lean Discipline, Failure Modes, and Measurement

Organizational complexity must not exceed project complexity. A new role must solve a problem that has already appeared, not prevent one that is merely imagined; a retained role must keep proving that its value exceeds its coordination cost.

Xiaohongshu @就很菜 · veggiedesu

Conditions for adding a role

- ◆ It brings a new source of information.
- ◆ It brings a new specialist capability.
- ◆ It brings a new independent perspective.
- ◆ It brings a new supervisory mechanism.

Common failure modes

FAILURE MODE	HOW IT SHOWS UP
Prompt cosplay	Titles like CEO or Reviewer exist, but there are no permissions, no defined inputs and outputs, and no escalation rules.
Same-source self-review	One model produces the plan, then a few roles sharing the same context are asked to object mildly.
Owner abdication	"I'm not technical" becomes the reason not to define acceptance criteria or risk boundaries.
Verbal reporting replaces records	The Investor Office listens to the MD's summary instead of reading the original organizational record.
Narrative capture	The story or the demo starts driving product facts and priorities in reverse.
Permanent roles	Once created, a role is never re-justified, and the organization keeps inflating.

Suggested organizational KPIs

- ◆ Whether the time the Owner spends reading raw logs is falling.
- ◆ Whether major risks are being found and escalated earlier.
- ◆ The ratio of valid findings to false positives from red teams.

- ◆ Whether the reasons for overturned or reworked decisions remain traceable.
- ◆ Whether Project State matches actual delivery.
- ◆ Whether the Academy is improving the Owner's independent judgment.
- ◆ Whether GTM helps external audiences understand the project's value more accurately.

SEC. 11 Field Record: Three Governance Interventions

The effectiveness of an institution does not show up in its diagram. It shows up in what the institution actually intercepted. The three records below come from the live project currently running this method; details have been anonymized.

RECORD · I

The instrument changed mid-measurement; the whole batch was voided

During an acceptance review executed personally by the Owner, the MD altered the wording of part of the review material midway. An independent red team ruled that changing the object of measurement while measurement is in progress contaminates the entire batch, not merely the parts that were edited. The review round was marked invalid in full and redone against a frozen version. The original records, the edits, and the reason for invalidation were preserved and not deleted.

The reviewer refused to sign off on a summary

In a milestone re-review, the Strategic Board refused to issue a pass verdict on the basis of an implementation summary alone. Its reasoning: if the review step accepts a verbal summary as evidence, the top of the control chain becomes the weakest link in it. That round's conclusion was explicitly downgraded to "a judgment on the described design only," kept strictly separate from conclusions reached through independent verification.

Order of evidence moved from believed to provable

A red team required that key review material be committed to a version snapshot before it is handed to the reviewer, and that the review output live in a later snapshot. The order of material and conclusion thereby became a verifiable fact rather than a procedural claim.

What they have in common: none of the three interventions caught a capability defect in a model. Each caught the moment when the process, under pressure, wanted to cut a corner.

SEC. 12 Practice → Evidence: an Auditable Governance-Learning Loop

Application projects provide facts and experience, but they may not rewrite the shared method. An unverified hypothesis may not enter the canonical method early.

Practice	Raw observation, friction, failure, or near miss	Describe what happened before abstracting a rule
Evidence	Reproduction steps, version snapshots, counterexamples, applicability boundary	Separate facts, source attestation, and unknowns
Proposed Change	Rule proposal, migration impact, rollback, version candidate	A proposal does not mean the method has changed
Decision	Accept, modify, reject, or continue testing, with rationale	Internal patch/minor changes may be approved by the portfolio governance office; major principles and publication remain Owner decisions
Versioned Method	Version, Change Log, evidence references, migration note	Only approved changes enter a formal version
Re-test	Results in the source context and a transfer context	When contradicted, roll back, narrow the boundary, or return to hypothesis

When governance review starts

- ◆ The same friction appears in two projects.
- ◆ One project exposes a material control gap or near miss.
- ◆ Unclear role or authority boundaries cause rework.
- ◆ Practice contradicts an existing method statement.
- ◆ A reproducible, transferable governance mechanism appears.
- ◆ Agentic automation exposes a new supervision or rollback need.
- ◆ A major milestone provides sufficient new evidence.

Version boundaries

LEVEL	TYPICAL CHANGE	APPROVAL BOUNDARY
Patch	Typo, clarification, citation, or non-substantive evidence addition	No change to authority, control gates, or behavior requirements
Minor	Backward-compatible mechanism, trigger, record type, or low-risk control	No change to core decision rights, risk appetite, or human decision boundary
Major	Change to a core principle, authority, mandatory control, or human decision boundary	Owner decides

SEC. 13 Capability Claims, Conclusion Provenance, and Derivation Integrity

Cross-project practice shows that governance must preserve evidence and constrain what the evidence can support. The three rules below are domain-neutral. Implementations may differ, but they may not cross the same fact boundary.

1. Capability Claim Attestation

An `Agent-executed`, `AI-executed`, automated, or model-evaluated capability claim must be bound to evidence of the actual runtime, provider, execution event, and material configuration or output. An interface, fixture, mock, provider adapter, or `agent-ready` structure proves readiness, not that an Agent executed the reviewed case.

2. Conclusion Provenance

A `human-only`, human-approved, or reviewer-approved conclusion cannot be established by a label alone. It must be verifiable or recomputable from exception state and a human-review chain that answers who reviewed what evidence, what decision was made, and whether unresolved exceptions remained.

Xiaohongshu @就很菜 · veggiedesu

3. Derivation Integrity

An input or raw hash proves identity and immutability of that object. It does not prove that a downstream draft, recommendation, or conclusion was derived from it. Decision-critical chains must connect `raw` → `draft` → `conclusion` through replayable transformation, canonical equality, a testable equivalence rule, or a derivation manifest.

APPLICATION PORTFOLIO

RiskFirewall AI — Product Risk Review (Complex Instruments · Second Line) and RiskFirewall AI — Risk Control Assurance (Transactions, Processes & AI Actions · Third Line) are the two application lines practicing this method.

Naming boundary: `RiskFirewall AI` is a portfolio brand, not a fourth repository. It does not prove live AI execution, automated decision-making, a production firewall, a deployed control system, or identical implementation between the applications.

Limits retained: a provider interface is not live execution; source authenticity and semantic sufficiency may still require human review; a hash is not semantic derivation; and evidence maturity must be stated separately for each application.

SEC. 14 Minimum Viable Implementation

A minimum viable version does not need a dozen Agents. Start with one production core that holds write access, one strategic challenge role, three read-only views, and five basic record types.

- 01 Write a one-page Investor Mandate.
- 02 Make explicit the authority boundaries of the Owner, the MD, and the Strategic Board.
- 03 Have the MD continuously maintain a Project Ledger and an append-only Decision Log.
- 04 Define which project changes actively trigger the Investor Office.
- 05 Establish a three-tier review protocol for low, medium, and high risk.

- 06 Ensure the Academy and GTM stay read-only and never modify the Product in reverse.
- 07 Define the final Acceptance Gate and the residual risk that is acceptable.
- 08 Establish the Practice → Evidence → Proposed Change → Decision → Versioned Method → Re-test record.
- 09 Audit capability claims, human-conclusion provenance, and decision-critical derivation chains.
- 10 Update organizational rules, the Change Log, and the Capability Ledger at the end of every milestone.

Acceptance Gate

ACCEPTANCE LAYER

WHAT IS JUDGED

Functional	Whether the deliverable works and the critical tests pass
Assurance	Whether evidence, red-teaming, risk records, and failure handling are complete
Investor	Whether the result still fits the Investor Mandate and the risk appetite

The final state may be **accepted, accepted with residual risks, conditionally accepted, rework required, paused, or terminated** — not merely "done."

This method is not about making AI look like a company. What it sets out to solve is this: how to organize probabilistic, not-fully-reliable models into a production system that is replaceable, traceable, auditable, and capable of learning.

You are not hiring a model.

You are building an institution in which models are replaceable, facts are traceable, risk is escalable, and the Owner always steers.

NOTE – This document summarizes a method currently practiced, challenged, and iterated across two application projects. It is not presented as an industry-validated standard, and it does not describe unpublished candidates, private implementations, or interface readiness as public capability.

GOVERNANCE-DRIVEN AGENTIC CODING

XIAOHONGSHU @就很菜 · VEGGIEDESU

WHITEPAPER NO. 01 · V1.4